Trường Đại học Khoa học tự nhiên
Khoa Công nghệ thông tin

NĂM HỌC 2025-2026

ĐỒ ÁN MÔN HỌC

CSC12001 - AN TOÀN VÀ BẢO MẬT DỮ LIỆU TRONG HTTT

Giảng viên: TS. Phạm Thị Bạch Huệ
ThS. Lương Vĩ Minh
ThS. Tiết Gia Hồng

Nội dung

PHÂN HỆ 1: ỨNG DỤNG QUẢN TRỊ CSDL ORACLE **2**

PHÂN HỆ 2: ỨNG DỤNG QUẢN LÝ DỮ LIỆU Y TẾ **3**

Yêu cầu 1: Giải pháp cấp quyền truy cập và cài đặt giao diện 5

Yêu cầu 2: Cơ chế phát tán thông báo dùng OLS và cài đặt giao diện 5

Yêu cầu 3: Vận dụng cơ chế kiểm toán 6

Yêu cầu 4: Sao lưu và phục hồi dữ liệu 7

MỘT SỐ QUY ĐỊNH **8**

PHÂN HỆ 1: ỨNG DỤNG QUẢN TRỊ CSDL ORACLE

Dành cho người quản trị cơ sở dữ liệu

Sinh viên hãy xây dựng ứng dụng ***WinForm*** cho phép người dùng có quyền quản trị trên Oracle DB Server thực hiện được các thao tác sau:

1. Cho phép tạo mới, xóa, sửa (hiệu chỉnh) user hoặc role.
2. Xem danh sách tài khoản người dùng và role trong hệ thống Oracle DB Server.
3. Cho phép thực hiện việc cấp quyền:
    a. Cấp quyền cho user, cấp quyền cho role, cấp role cho user.
    b. Quá trình cấp quyền có tùy chọn là có cho phép người được cấp quyền có thể cấp quyền đó cho user/ role khác hay không (có chỉ định WITH GRANT OPTION hay không).
    c. Thực hiện cấp quyền trên một số loại đối tượng của CSDL như: table, view, stored procedure, function; quyền select, update phải cho phép phân quyền tính đến mức cột; quyền insert, delete thì không. Lưu ý, quyền trên các loại đối tượng khác nhau có thể khác nhau.
4. Cho phép thu hồi quyền từ user hoặc role.
5. Xem thông tin về quyền của mỗi user hoặc role trên các đối tượng dữ liệu.

PHÂN HỆ 2: ỨNG DỤNG QUẢN LÝ DỮ LIỆU Y TẾ

Một bệnh viện X quản lý việc khám chữa bệnh thông qua một hệ thống thông tin quản lý S.

BỆNHNHÂN (MÃBN, TÊNBN, PHÁI, NGÀYSINH, CCCD, SỐNHÀ, TÊNĐƯỜNG, QUẬNHUYỆN, TỈNHTP, TIỀNSỬBỆNH, TIỀNSỬBỆNHGĐ, DỊỨNGTHUỐC)

Mỗi bệnh nhân được bệnh viên cấp mã duy nhất (MÃBN), có tên (TÊNBN), phái (PHÁI), ngày sinh (NGÀYSINH), căn cước công dân (CCCD), địa chỉ (SỐNHÀ, TÊNĐƯỜNG, QUẬNHUYỆN, TỈNHTP), và tiền sử bệnh của bệnh nhân (TIỀNSỬBỆNH) và gia đình (TIỀNSỬBỆNHGĐ), cũng như tình trạng dị ứng thuốc nếu có (DỊỨNGTHUỐC).

NHÂNVIÊN (MÃNV, HỌTÊN, PHÁI, NGÀYSINH, CMND, QUÊQUÁN, SỐĐT, VAITRÒ, CHUYÊNKHOA)

Quan hệ NHÂNVIÊN chứa dữ liệu về các nhân viên trong bệnh viện. Mỗi nhân viên có mã (MÃNV), họ tên (HỌTÊN), phái (PHÁI), ngày sinh (NGÀYSINH), số chứng minh nhân dân (CMND), quê quán (QUÊQUÁN), số điện thoại (SỐĐT), thuộc chuyên khoa nào (CHUYÊNKHOA). Thuộc tính VAITRÒ nhận một trong các giá trị sau: “Điều phối viên”, “Bác sĩ/Y sĩ”, “Kỹ thuật viên”, “Bệnh nhân”.

HSBA (MÃHSBA, MÃBN, NGÀY, CHẨNĐOÁN, ĐIỀUTRỊ, MÃBS, MÃKHOA, KẾTLUẬN): mỗi hồ sơ bệnh án (HSBA) có một mã duy nhất (MÃHSBA), liên quan đến một bệnh nhân (MÃBN), được lập vào một ngày (NGÀY), có chẩn đoán (CHẨNĐOÁN), hướng điều trị (ĐIỀUTRỊ) của y sĩ hoặc bác sĩ điều trị (MÃBS). Hồ sơ bệnh án thể hiện bệnh nhân được tiếp nhận khám và điều trị tại một khoa có mã là MÃKHOA, với kết luận của y sĩ hoặc bác sĩ điều trị là KẾTLUẬN.

HSBA_DV (MÃHSBA, LOẠIDV, NGÀYDV, MÃKTV, KẾTQUẢ): ghi nhận các dịch vụ hỗ trợ chẩn đoán (LOẠIDV) đã được thực hiện theo chỉ định của y sĩ hoặc bác sĩ điều trị (ví dụ các loại xét nghiệm, chụp hình, …), vào một ngày (NGÀYDV) liên quan đến một hồ sơ bệnh án (MÃHSBA), người thực hiện dịch vụ (MÃKTV) và kết quả (KẾTQUẢ).

ĐƠNTHUỐC (<u>MÃHSBA, NGÀYĐT, TÊNTHUỐC,</u> LIỀUDÙNG) là đơn thuốc mà y sĩ hoặc bác sĩ điều trị cho bệnh nhân (qua MÃHSBA) đã chỉ định vào ngày (NGÀYĐT) gồm tên thuốc (TÊNTHUỐC) và liều dùng (LIỀUDÙNG).

Cơ sở dữ liệu được cài đặt trên **Oracle**. Hệ thống dùng chính sách đóng (người dùng *u* cần được cấp quyền *p* trên đối tượng dữ liệu *o* mới có thể thực hiện *p* trên *o*). DBA trong hệ thống S thực hiện việc cấp quyền cho nhân sự trong toàn hệ thống theo mô tả như sau:

TC#1: Ngoài DBA, tất cả người dùng trong hệ thống S gồm những nhân viên trong quan hệ NHÂNVIÊN và cả những bệnh nhân trong quan hệ BỆNHNHÂN. DBA tạo tài khoản cho tất cả những người dùng này, và nhập liệu cho các bảng dữ liệu như NHÂNVIÊN. DBA không tự định nghĩa bảng (table) dùng để quản lý tài khoản người dùng mà sử dụng thông tin tài khoản do Hệ quản trị CSDL Oracle quản lý. Bằng cách nào DBA có thể kết nối một tên tài khoản với 1 dòng dữ liệu là người dùng tương ứng (trong quan hệ NHÂNVIÊN và BỆNHNHÂN) mà không phải truy cập dữ liệu từ nhiều hơn 1 bảng, đồng thời phải ép thỏa các chính sách bảo mật liên quan đến những người dùng này.

TC#2: Có 20 nhân viên với vai trò **"Điều phối viên"**. Các nhân viên giữ vai trò "Điều phối viên" có thể **xem, thêm và sửa** dữ liệu trên quan hệ BỆNHNHÂN, tạo mới (thêm) hồ sơ bệnh án (HSBA), được điều phối y bác sĩ phụ trách hồ sơ bệnh án (cập nhật giá trị trường MÃKHOA MÃBS), được điều phối kỹ thuật viên (MÃKTV) thực hiện các dịch vụ hỗ trợ chẩn đoán do bác sĩ chỉ định.

TC#3: Có 100 nhân viên với vai trò **"Bác sĩ/ y sĩ"**, có chức năng:

a. Xem các hồ sơ bệnh án mà bác sĩ/ y sĩ đó đã điều trị.
b. Thêm, xóa dòng trên quan hệ HSBA_DV, là các dịch vụ cần thực hiện thêm liên quan hồ sơ bệnh án mà Bác sĩ/ y sĩ phụ trách, giúp Bác sĩ/ y sĩ có chẩn đoán chính xác trong quá trình điều trị bệnh.
c. Cập nhật giá trị các trường CHẨNĐOÁN, ĐIỀUTRỊ, KẾTLUẬN liên quan các hồ sơ bệnh án mà bác sĩ/ y sĩ phụ trách. Các hành vi cập nhật trên các trường này đều được hệ thống ghi vết.
d. Được xem danh sách bệnh nhân liên quan đến các hồ sơ bệnh án mà y sĩ, bác sĩ đã điều trị. Được cập nhật giá trị các trường TIỀNSỬBỆNH,

TIỀNSỬBỆNHGĐ, DỊỨNGTHUỐC của các bệnh nhân (BỆNHNHÂN) mà bác sĩ/ y sĩ điều trị.

e. Thêm, xóa, cập nhật trên quan hệ ĐƠNTHUỐC liên quan đến các hồ sơ bệnh án mà y sĩ hoặc bác sĩ đó điều trị. Việc điều chỉnh đơn thuốc liên quan đến tên thuốc (TÊN THUỐC), liều dùng (LIỀU DÙNG) sẽ được ghi vết sau khi đơn thuốc đã được tạo.

TC#4: Có 50 nhân viên giữ vai trò **"Kỹ thuật viên"**. Các kỹ thuật viên thực hiện các dịch vụ theo chỉ định của bác sĩ và sự điều phối của điều phối viên và ghi kết quả tại trường KẾTQUẢ trong quan hệ HSBA_DV. Các kỹ thuật viên chỉ có thể xem các dòng trong quan hệ HSBA_DV do mình được điều phối và thực hiện. Các thao tác cập nhật trên trường KẾTQUẢ đều được ghi vết.

TC#5: Hệ thống hiện tại có khoảng 100000 người dùng là **"Bệnh nhân"**. Trên hệ thống S, trừ DBA, mỗi nhân viên hoặc bệnh nhân đăng nhập chỉ có thể xem thông tin của chính mình, (trên bảng NHÂNVIÊN nếu là nhân viên, trên bảng BỆNHNHÂN nếu là bệnh nhân), và có thể chỉnh sửa các trường (trừ trường liên quan mã, họ tên, phái, ngày sinh, CCCD, vai trò, chuyên khoa tùy quan hệ tương ứng) liên quan đến chính người đó.

Yêu cầu 1: Giải pháp cấp quyền truy cập và cài đặt giao diện

Câu 1: Em hãy cài đặt cơ sở dữ liệu và thiết lập tài khoản theo mô tả ở TC#1.

Câu 2: Em hãy ép thỏa các chính sách bảo mật liên quan vai trò và "Kỹ thuật viên" và "Bệnh nhân" *dùng cơ chế **RBAC*** theo mô tả và cài đặt giao diện cho những người dùng liên quan.

Câu 3: Em hãy ép thỏa các chính sách bảo mật liên quan vai trò "Điều phối viên" và "Y sĩ/ Bác sĩ" dùng *chế **VPD*** theo mô tả và cài đặt giao diện cho những người dùng liên quan.

Yêu cầu 2: Cơ chế phát tán thông báo dùng OLS và cài đặt giao diện

Dựa vào chuyên môn, giả sử hiện tại bệnh viện có 3 khoa: Khoa tiêu hóa, Khoa thần kinh, Khoa tim mạch.

Ngoài ra, bệnh viên có 3 cơ sở tại: *Hồ Chí Minh, Hải Phòng, Hà Nội*. Có sự phân chia vai trò người dùng theo 03 cấp bậc: **Ban Giám đốc > Lãnh đạo khoa > Nhân viên**. Bệnh viện cần

gửi những dòng trong quan hệ THÔNGBÁO, gồm các trường NỘIDUNG, NGÀYGIỜ và ĐỊAĐIỂM về những cuộc họp khẩn đến các vai trò trong bệnh viên dùng cơ chế OLS (Oracle Label Security).

Hãy thiết lập hệ thống nhãn gồm 03 thành phần, có thể điều chỉnh mô hình dữ liệu (nếu cần thiết) để hệ thống có thể đáp ứng các yêu cầu sau, đồng thời, cài đặt giao diện minh hoạ trên ứng dụng.

Đối tượng cần gán nhãn	**Định danh**	**Mô tả**
Người dùng	u1	Giám đốc có thể đọc được toàn bộ thông báo
	u2	Lãnh đạo Khoa tim mạch tại Hồ Chí Minh
	u3	Lãnh đạo Khoa thần kinh tại Hà Nội
	u4	Nhân viên thuộc Khoa thần kinh tại Hồ Chí Minh
	u5	Nhân viên thuộc Khoa tim mạch tại Hồ Chí Minh
	u6	Lãnh đạo phòng có thể đọc các thông báo của Khoa tim mạch tại Hồ Chí Minh
	u7	Lãnh đạo phòng có thể đọc được toàn bộ thông báo phù hợp với cấp lãnh đạo phòng
	u8	Nhân viên thuộc Khoa Tiêu hóa tại Hà Nội
Dữ liệu	t1	Gửi đến toàn bộ nhân viên
	t2	Gửi đến toàn bộ Ban giám đốc
	t3	Gửi đến các lãnh đạo khoa
	t4	Gửi đến lãnh đạo Khoa tiêu hóa
	t5	Gửi đến nhân viên Khoa tiêu hóa ở Hồ Chí Minh
	t6	Gửi đến nhân viên Khoa tiêu hóa ở Hà Nội
	t7	Gửi đến lãnh đạo Khoa tiêu hóa và Khoa thần kinh tại Hải Phòng

Yêu cầu 3: Vận dụng cơ chế kiểm toán

Sinh viên hãy thiết lập các yêu cầu kiểm toán như sau và đọc nhật ký kiểm toán ghi nhận được (không cần cài đặt giao diện):

1. Kích hoạt kiểm toán hệ thống.
2. Thực hiện kiểm toán dùng *Standard audit*: theo dõi hành vi của những user cụ thể trên những đối tượng cụ thể của cơ sở dữ liệu gồm table, view, stored procedure, function, có thiết lập theo dõi các hành vi hiện thành công hay không thành công. Sinh viên tự đề nghị 5 ngữ cảnh khác nhau để thiết lập kiểm toán và kiểm chứng lại nhật ký kiểm toán.

3. Sinh viên có thể dùng *Fine-grained Audit* hoặc *Unified Audit* để thực hiện kiểm toán trong các tình huống sau và tạo tình huống để có dữ liệu nhật ký kiểm toán với các hành vi sau:
    a. Hành vi cập nhật trên thuộc tính **MÃHSBA, NGÀYĐT, TÊNTHUỐC, LIỀUDÙNG** của quan hệ **ĐƠNTHUỐC** của y sĩ/ bác sĩ điều trị sau khi đơn thuốc đã được chỉ định (được tạo xong).
    b. Hành vi của người dùng thuộc vai trò "Y sĩ / Bác sĩ" đã cập nhật thành công trên các trường **CHẨNĐOÁN, ĐIỀUTRỊ, KẾTLUẬN** của hồ sơ bệnh án (HSBA) mà y sĩ/ bác sĩ đó điều trị.
    c. Hành vi của người dùng cập nhật bất hợp pháp trên các trường **CHẨNĐOÁN, ĐIỀUTRỊ, KẾTLUẬN.**
    d. Hành vi thêm, xóa, sửa bất hợp pháp trên quan hệ **HSBA_DV**.
4. Đọc xuất dữ liệu kiểm toán ở mỗi trườn hợp.

Yêu cầu 4: Sao lưu và phục hồi dữ liệu

Sinh viên hãy tìm hiểu về cơ chế sao lưu và phục hồi dữ liệu do các HQT CSDL cung cấp và cài đặt chức năng sao lưu (chủ động, tự động) và khôi phục dữ liệu dựa vào nhật ký kiểm toán ở Yêu cầu 3 (sau khi có sự cố). Với yêu cầu 4, không yêu cầu sinh viên cài đặt giao diện.

1. Tìm hiểu các phương pháp thực hiện sao lưu và phục hồi dữ liệu.
2. Hãy hiện thực các phương pháp đó trên HQT CSDL Oracle.
3. Đánh giá ưu khuyết điểm các phương pháp đã tìm hiểu và thử nghiệm.
4. Kết luận.

MỘT SỐ QUY ĐỊNH

1. Nhóm phải thực hiện cả hai phân hệ, cùng ứng dụng.
2. Kế hoạch chấm đồ án sẽ được thông báo cụ thể trên Moodle.
3. **Cuốn báo cáo đồ án:**
    a. Trình bày giải pháp lý thuyết ngắn gọn, dễ hiểu, ghi rõ tài liệu tham khảo, không dịch lại tài liệu, chủ yếu là phần tóm lược những gì tìm hiểu được, nhận xét, đánh giá, thuyết minh các kết quả đạt được.
    b. Nhóm trưởng làm bảng phân công công việc và đánh giá thành viên trong nhóm (đóng chung trong cuốn báo cáo đồ án). Ghi rõ mỗi thành viên hoàn thành bao nhiêu % công việc được giao và mỗi thành viên đóng góp bao nhiêu % để hoàn thành đồ án (giả sử mỗi phân hệ của đồ án ứng với 100% thì mỗi thành viên hoàn thành bao nhiêu % trong từng phân hệ).
4. Nộp cuối kỳ:
    a. Bản in báo cáo trên giấy nộp vào ngày chấm đồ án, đồng thời cũng nộp trên Moodle (trước deadline).
    b. Gồm các tập tin MS Word báo cáo (báo cáo cuốn đồ án), source code, script CSDL (gồm script schema, data). Tên tập tin đặt theo quy định là *mã sinh viên của các thành viên trong nhóm, cách nhau bởi dấu '_'*. Tất cả tập tin được lưu trong thư mục với tên theo quy định: **ATBM-2026-MãNhóm** (Mã Nhóm xem trong danh sách phân công nhóm đồ án trên Moodle).
5. Tất cả các thành viên của nhóm đều cần có khả năng thực hiện các yêu cầu của đồ án. Bất kỳ sinh viên nào cũng có thể được Giáo viên chấm đồ án yêu cầu thực hiện tại chỗ việc cài đặt một số chính sách bảo mật.
6. **Bài giống nhau hoặc có copy/ sao chép: tất cả thành viên đều 0 điểm môn học.**

Hết